Admin Panel and RBAC: Approved Plan

Graph Knowledge System. Branch: feature/admin-panel.

Task

Add authentication, role-based access control, company-level data isolation and audit logging to the Graph Knowledge System, and build an admin panel to manage it. Backend is FastAPI, the admin UI is React.

My solution

ROLES

- sysAdmin: platform-wide. Manages companies and users of every company. Belongs to no company.
- admin: manages the users of their own company only.
- user: uses the graph inside their own company. No admin APIs.

Permissions are a fixed role-to-permission map in code: company:manage, user:manage, audit:read, graph:read, graph:write.

Permission	sysAdmin	admin	user
company:manage	yes	no	no
user:manage	yes	yes (own company)	no
audit:read	yes	yes (own company)	no
graph:read / graph:write	yes	yes	yes

AUTHENTICATION

Login with email and password. Passwords are stored as bcrypt hashes. A successful login returns a short-lived JWT (60 minutes). Every request loads the user from the database, so a deactivated user, or a user whose company is deactivated, loses access immediately even with a valid token. Failures return a generic “Unauthorized access”.

AUTHORIZATION

Each admin route declares the permission it needs. A missing or invalid token gives 401, a role without the permission gives 403. The check lives in the API, the UI only hides controls.

COMPANY ISOLATION

One helper adds the company filter to every query for non-sysAdmin users. The company comes from the logged-in user, never from the request. A user in another company is treated as not found (404), so records of other companies cannot even be probed. An admin who sends a different company_id when creating a user still creates the user in their own company.

ADMIN RULES

- A company must always keep at least one active admin.
- Nobody can change their own role or deactivate themselves.
- A sysAdmin’s role cannot be changed, and only a sysAdmin can create another sysAdmin.
- Users cannot be added to an inactive company.

AUDIT LOG

Every administrative action writes one row in the same transaction as the change: who, what, which record, which company, and the details. Failed logins are recorded too. The log is append-only, there is no edit or delete endpoint. An admin reads their own company’s log, a sysAdmin reads all.

CONFIDENTIAL

Actions recorded: company.create, company.update, company.activate, company.deactivate, user.create, user.update, user.role_change, user.activate, user.deactivate, auth.login_failed.

ADMIN UI

Sign in page, then role-aware navigation: Users (admin, sysAdmin), Companies (sysAdmin only), Audit log (admin, sysAdmin). Users with the user role see a no-access message. Controls that are not allowed for a row are not shown at all.

PROJECT LAYOUT

- backend/app: config, db, models, security, deps (auth, permissions, isolation), audit, routers/auth.py, routers/admin.py
- backend/tests: pytest suite
- admin-ui: React app built with Vite

VERIFICATION

- 15 automated tests: 401 and 403 checks, cross-company access returns 404, sysAdmin can cross companies, one audit row per change, last-admin and self-change guards, deactivated users and inactive companies are locked out.
- Manual check: sign in as each role and confirm only the intended pages and buttons appear.

LEFT OUT ON PURPOSE

Refresh tokens, password reset by email, and a database-backed permission table. Add them when a real need shows up.

CONFIDENTIAL